

MEDIROZA GENERAL HOSPITAL

Black-Box Penetration Testing Report

Report Detail	Value
Target	https://medirozahospital.com
Assessment Type	External Black-Box Web Application Penetration Test
Environment	Authorized educational testing environment
Scope	Mediroza General Hospital web application and publicly accessible supporting resources
Prepared By	Josiah Ayuba
Instructor	Waqas Karim (CCIE)
Assessment Period	5 Days

CONFIDENTIAL

Executive Summary

A black-box penetration test was conducted against the Mediroza General Hospital web application at <https://medirozahospital.com>. The assessment was performed within the authorized educational scope provided by Networkwalks. The engagement permitted testing of the target domain while excluding denial-of-service activities and social engineering.

Reconnaissance identified multiple application and infrastructure components. A significant confirmed issue was identified at the `/patient/` directory, where unauthenticated directory listing was enabled. The listing exposed application resources including `download.php`, `error_log`, `login.php`, `logout.php`, `portal.php`, and the `reports/` directory.

The assessment also identified a critical information disclosure involving an internal SQL database backup, `mediroza_db_backup_2019.sql`. The backup identified the internal database as `mediroza_hr` and indicated that it was generated by Mediroza CMS 1.4.2. It contained populated staff and shareholders tables, including employee personal and salary information and corporate ownership information.

Additional reconnaissance observations included `/staff/`, `/patient/`, and `/old/` paths in `robots.txt`, an exposed `/staff/login.php` endpoint, and externally accessible network services. These were not independently classified as vulnerabilities without additional evidence.

2. Scope and Methodology

2.1 Scope

Primary target:

<https://medirozahospital.com>

Testing was conducted from an external, unauthenticated perspective consistent with a black-box penetration test.

2.2 Testing Restrictions

- Testing was limited to the authorized target.
- Denial-of-service and destructive testing were not performed.
- Social engineering was not performed.
- Testing against unrelated systems was not performed.

2.3 Methodology

Phase 1 — Reconnaissance

- DNS and host discovery
- Service enumeration
- HTTP response analysis
- robots.txt and sitemap inspection
- Directory and endpoint discovery

Phase 2 — Web Application Enumeration

- Hidden directories
- Login interfaces
- Application endpoints
- File disclosure
- Directory indexing
- Backup files
- Error files
- Patient and staff functionality

Phase 3 — Access-Control Testing

- Investigation of discovered patient and staff endpoints for unauthenticated access and authorization weaknesses

Phase 4 — Sensitive-Data Analysis

- Review of accessible artifacts for personal, salary, corporate ownership, database, application and metadata exposure

Phase 5 — Evidence and Risk Assessment

- Documentation of affected resources, observed behavior, impact, evidence, severity and remediation

Evidence: An unauthenticated browser request to <https://medirozahospital.com/patient/> returned a directory index exposing reports/, download.php, error_log, login.php, logout.php, and portal.php.

3. Findings and Proof of Exploitation

F-01 — Unauthenticated Directory Listing

Severity: Medium

Affected resource:

<https://medirozahospital.com/patient/>

Description

The /patient/ directory was accessible without authentication and returned a directory listing containing application files and directories.

Evidence

Exposed Resource	Potential Purpose
reports/	Patient report storage/directory
download.php	File download functionality
error_log	Application/server error information
login.php	Patient authentication
logout.php	Session termination
portal.php	Patient portal functionality

Security Impact

Directory listing does not by itself demonstrate unauthorized access to patient records. However, it provides valuable reconnaissance information and identifies potentially sensitive functionality, including report storage, download handling, authentication, portal functionality and error logging.

Proof

An unauthenticated request to GET /patient/ returned a directory listing rather than denying directory browsing.

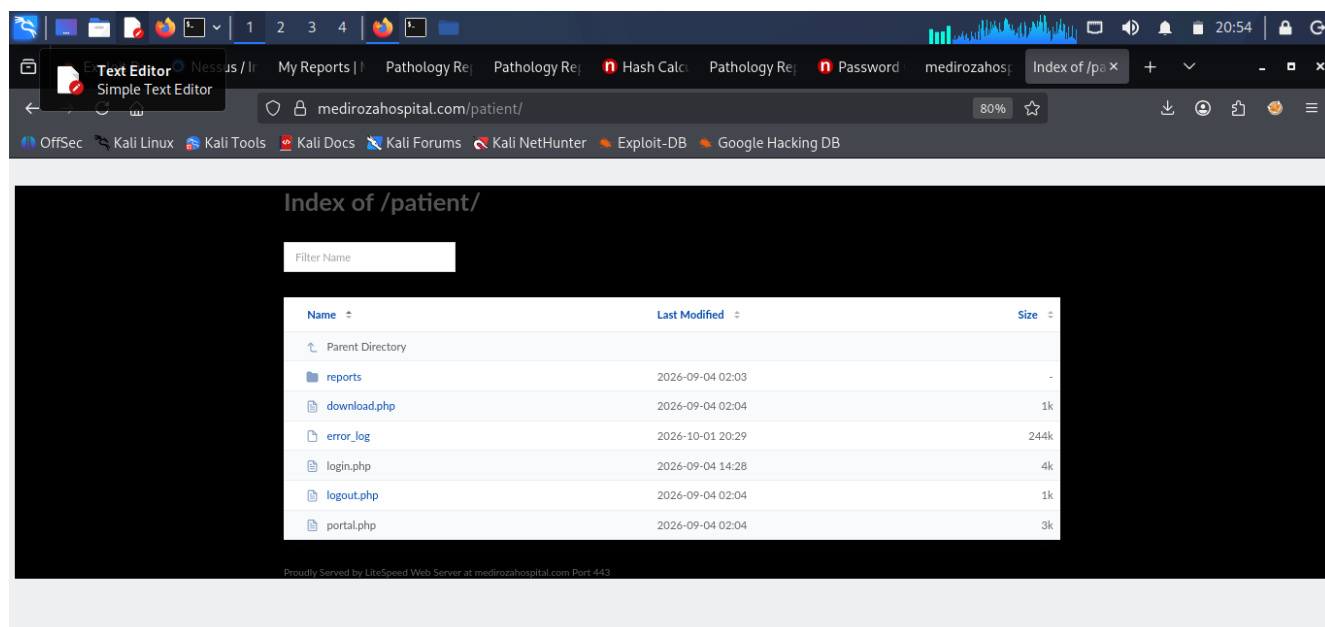


Figure 1 — Unauthenticated directory listing of the /patient/ application directory exposing patient-related application resources.

Recommendation

- Disable directory indexing on the web server.
- Apply authentication and authorization controls to patient resources.
- Prevent direct browsing of report directories.
- Restrict access to error_log.
- Review download.php for authorization enforcement.
- Review portal.php for authentication and session-management controls.
- Ensure sensitive files cannot be retrieved through predictable URLs.

F-02 — Exposure of Confidential Internal Database Backup

Severity: Critical

Affected artifact: mediroza_db_backup_2019.sql

Database: mediroza_hr

Application: Mediroza CMS 1.4.2

Description

An internal SQL database backup was exposed to an unauthorized party. The backup header identified the internal database and CMS version and explicitly indicated that it contained confidential staff and shareholder records.

Staff Data Exposure

Field	Information
Id	Employee database identifier
full_name	Employee name
job_title	Job position

Department	Department
Email	Employee email
Phone	Employee telephone number
national_id	National identification information
monthly_salary_zar	Monthly salary
date_joined	Employment date

The staff table contains 30 employee records.

Shareholder Data Exposure

Field	Information
Id	Shareholder database identifier
shareholder_name	Shareholder identity
share_percent	Ownership percentage
shares_held	Number of shares
share_class	Share classification

The shareholders table contains 10 shareholder records.

Security Impact

This finding represents a substantial confidentiality breach. Exposure of the staff table discloses employee identities, employment information, contact information, national identification information, and salary information. Exposure of the shareholder table discloses shareholder identities, ownership percentages, share quantities, and share classes. The information could facilitate targeted social engineering, identity-related fraud, privacy violations, and unauthorized disclosure of corporate ownership information.

Root Cause

The underlying issue is exposure of an internal database backup through a location accessible to an unauthorized party. Database backups should not be stored within a publicly accessible web root.

Recommendation

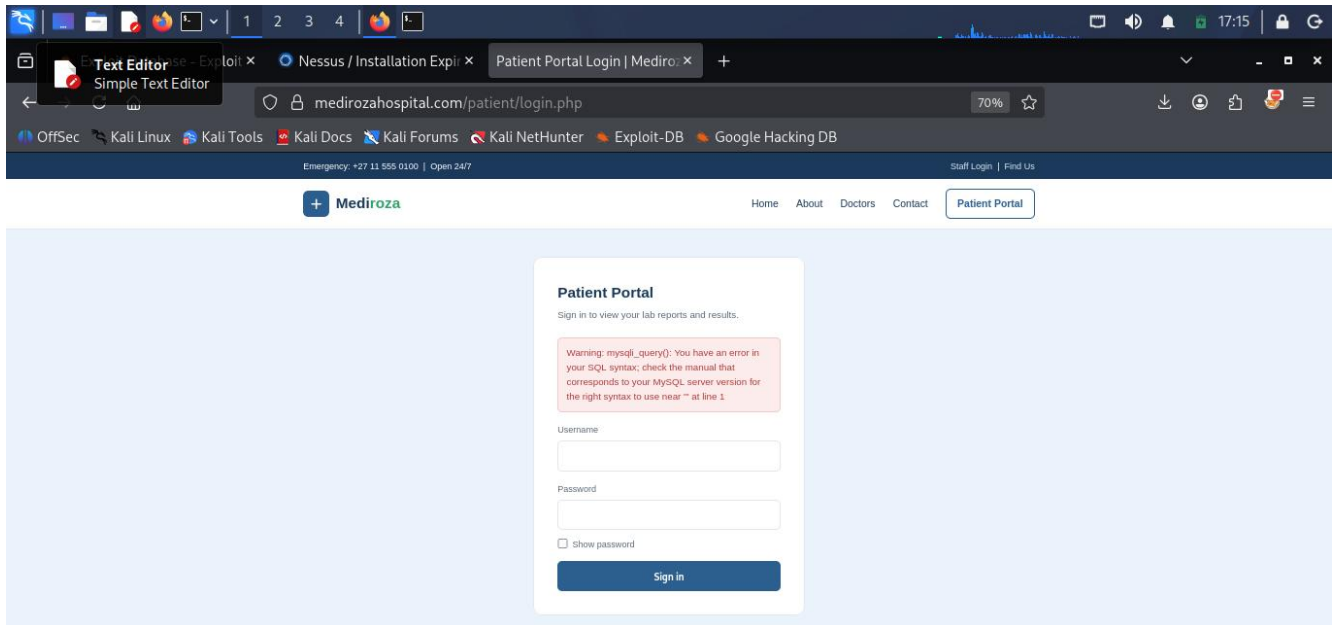
- Remove the exposed database backup from publicly accessible storage.
- Determine how the backup became accessible.
- Review web-server access logs for access to the backup.
- Rotate credentials associated with the exposed environment where appropriate.
- Search for other exposed backups and archive files.
- Store backups outside the web root with restrictive filesystem permissions.
- Prevent web servers from serving database backup formats.
- Implement regular security scanning for accidentally exposed backups.
- Review applicable privacy and data-protection obligations.

F-03 — Username Enumeration on Login Page

Severity: Medium

Finding: The patient login page at /patient/login.php was identified as permitting username enumeration. Differences in application responses can allow an unauthenticated user to determine whether particular usernames exist. This reduces the uncertainty an attacker faces when attempting targeted authentication attacks.

Recommendation: Use identical responses and timing for valid and invalid usernames, apply rate limiting and monitoring, and consider multi-factor authentication for sensitive accounts.

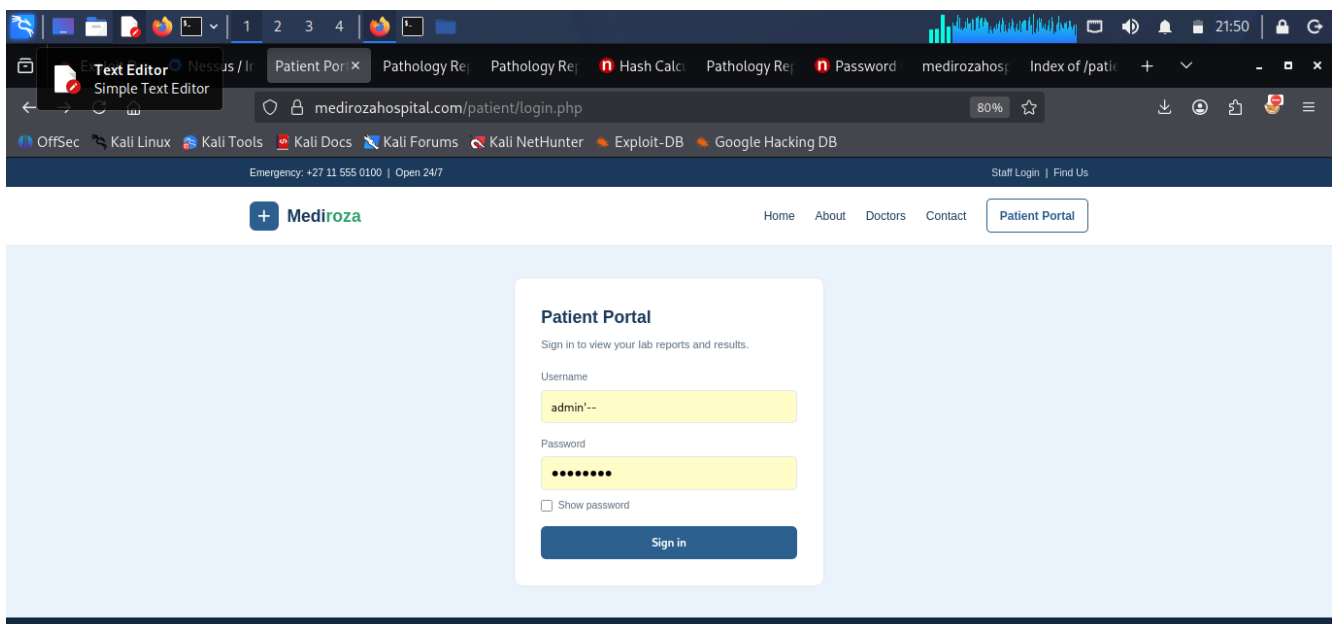


F-04 — SQL Injection Login Bypass

Severity: Critical

Finding: The supplied assessment evidence identifies SQL injection at /patient/login.php that can be used to bypass the intended authentication control. Successful exploitation of this weakness would allow an unauthenticated attacker to reach functionality intended for authenticated users.

Recommendation: Replace dynamically constructed SQL with parameterized queries or prepared statements, validate input server-side, apply least-privilege database permissions, and test authentication endpoints specifically for injection.

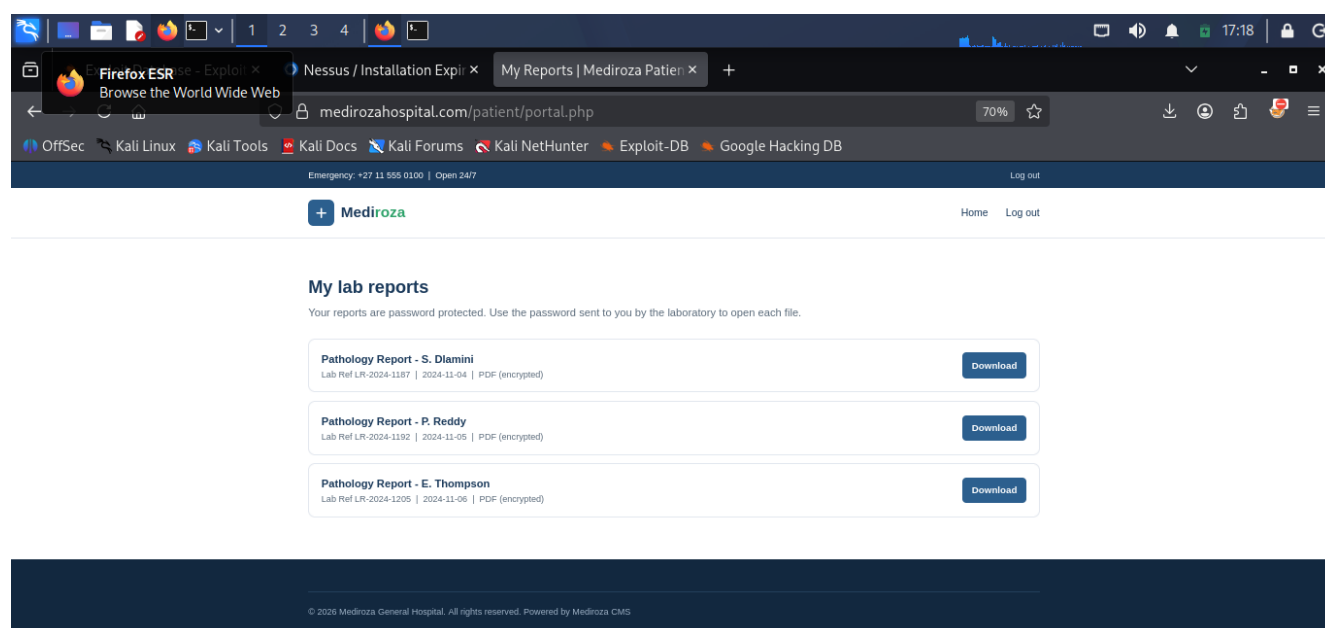


F-05 — Confidential PDFs Accessible After Login Bypass

Severity: High

Finding: The evidence indicates that confidential patient PDF reports under `/patient/reports/` become accessible after the login-bypass condition. This creates a direct confidentiality risk because patient reports may contain sensitive medical and personal information.

Recommendation: Enforce authorization on every individual report request, not only at login. Verify that the authenticated user is entitled to the requested report and keep report storage outside directly browsable web paths where practical.

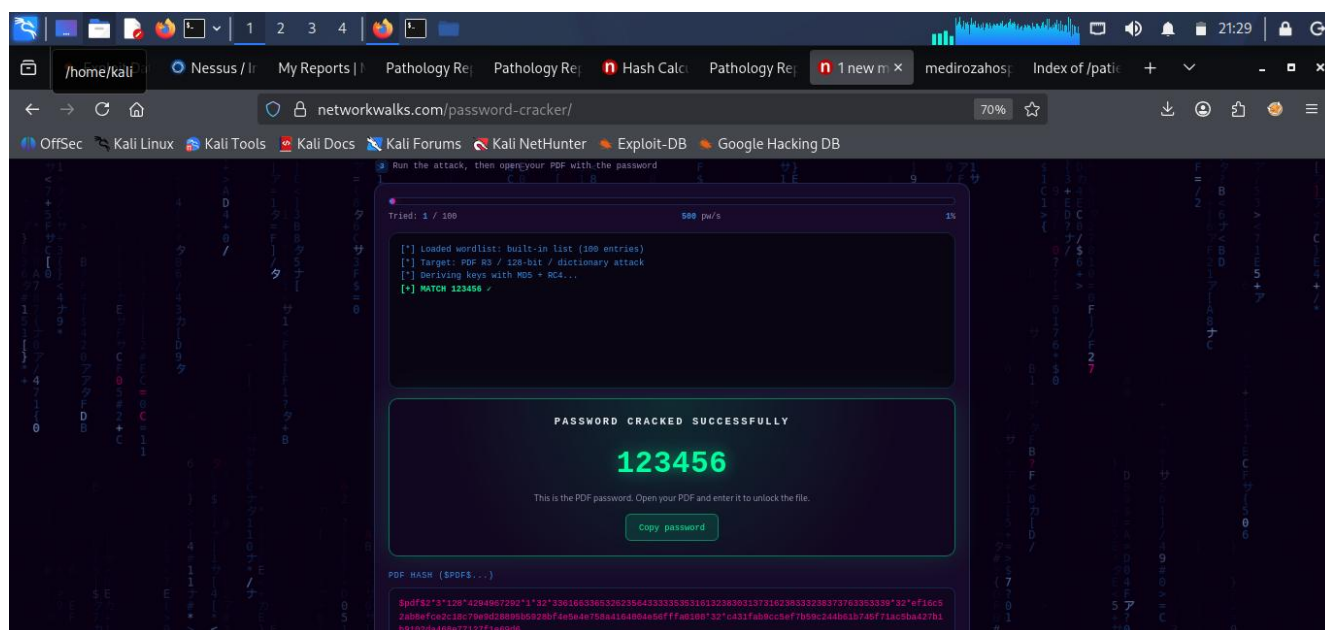
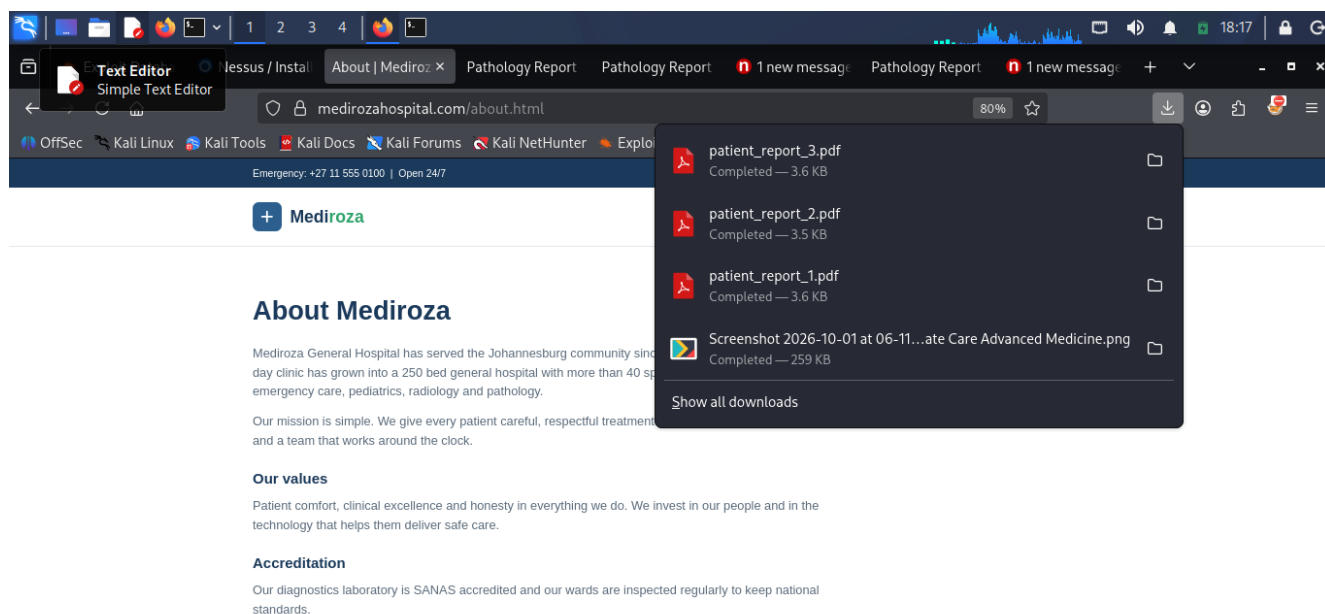


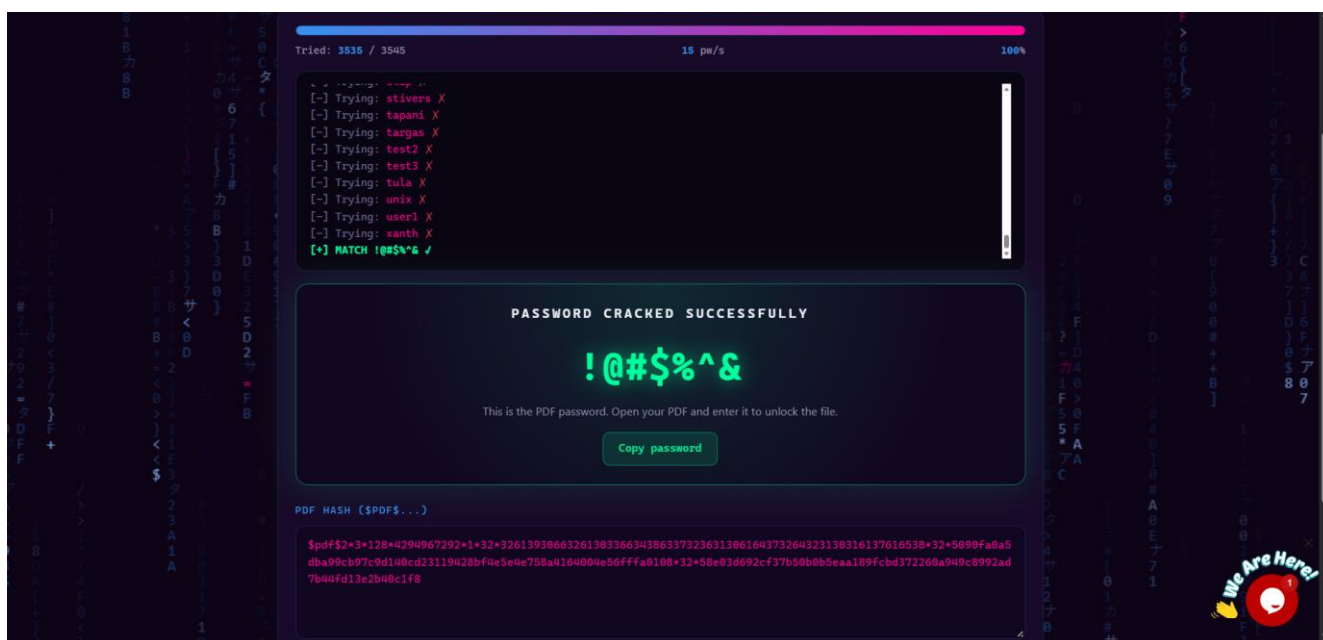
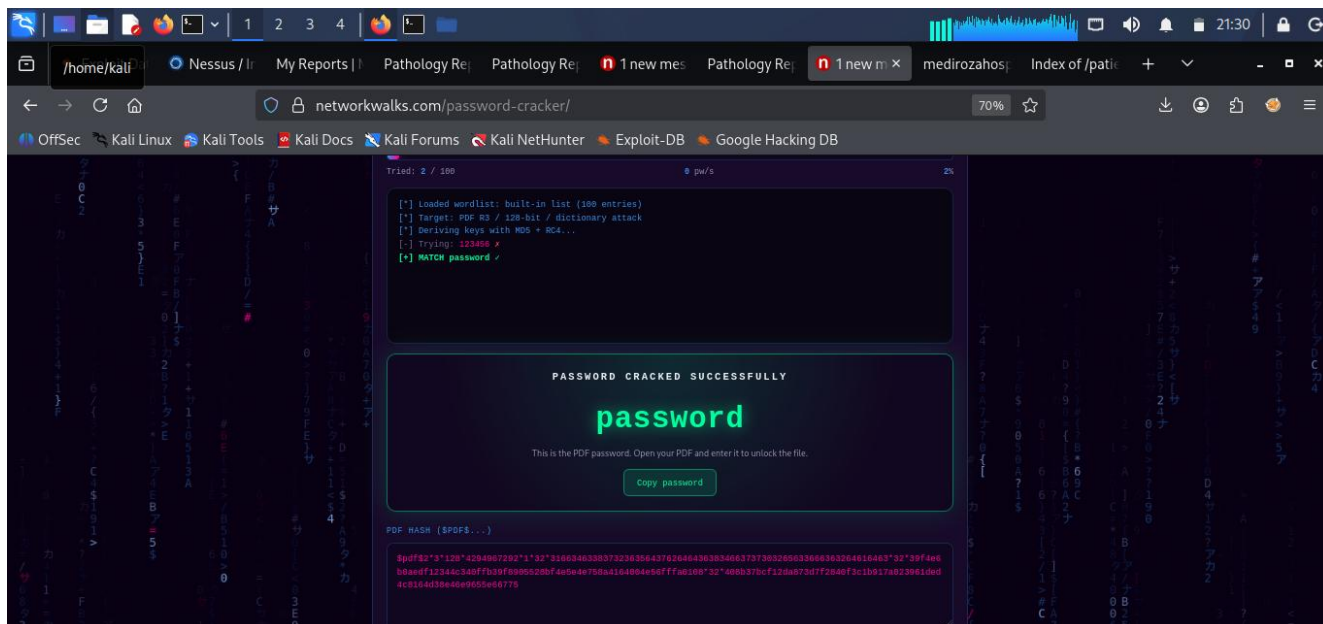
F-06 — Weak PDF Passwords

Severity: High

Finding: The supplied findings identify patient PDF passwords as sufficiently weak or predictable to be recovered with a wordlist. Consequently, possession of a PDF may provide an attacker with a practical path to its protected contents.

Recommendation: Use long, randomly generated and unique document passwords or a stronger document/key-management mechanism. Do not derive passwords from predictable patient, report, or organizational information.





file:///home/kali/Downloads/patient_report_1.pdf

OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB

1 of 1 100%



14 Cedar Avenue, Johannesburg, South Africa
Tel: +27 11 555 0100
medirozahospital.com

PATHOLOGY LABORATORY REPORT CONFIDENTIAL

Patient Name: **Sipho Dlamini** Report Date: **2024-11-04**
 Patient ID: **MG-P-10231** Referring Dr: **Dr. Anita Naicker**
 Date of Birth: **1984-06-12** Specimen: **Whole blood (EDTA)**
 Gender: **Male** Lab Ref No: **LR-2024-1187**

TEST	RESULT	UNIT	REFERENCE RANGE	FLAG
Haemoglobin	13.9	g/dL	13.0 - 17.0	Normal
White Cell Count	11.8	x10 ⁹ /L	4.0 - 11.0	HIGH
Platelet Count	245	x10 ⁹ /L	150 - 400	Normal
Fasting Glucose	5.4	mmol/L	3.9 - 5.5	Normal
Creatinine	88	umol/L	64 - 104	Normal

file:///home/kali/Downloads/patient_report_2.pdf

OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB

1 of 1 100%

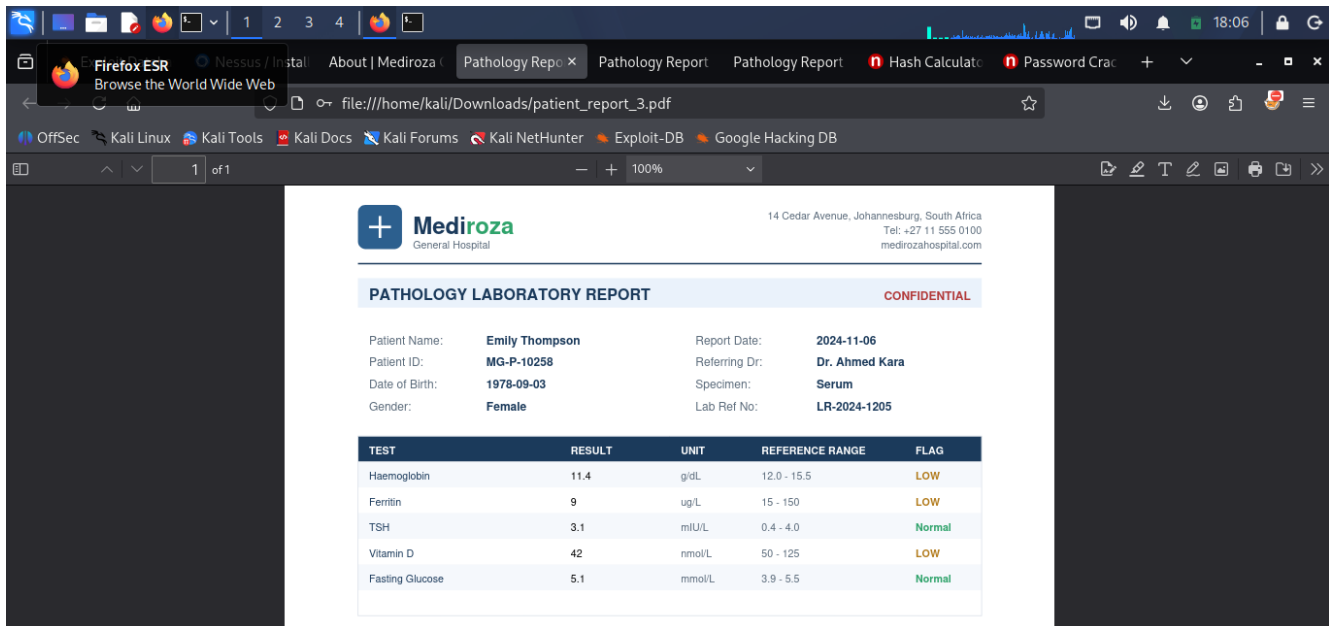


14 Cedar Avenue, Johannesburg, South Africa
Tel: +27 11 555 0100
medirozahospital.com

PATHOLOGY LABORATORY REPORT CONFIDENTIAL

Patient Name: **Priya Reddy** Report Date: **2024-11-05**
 Patient ID: **MG-P-10244** Referring Dr: **Dr. Johan van der Merwe**
 Date of Birth: **1991-02-28** Specimen: **Serum**
 Gender: **Female** Lab Ref No: **LR-2024-1192**

TEST	RESULT	UNIT	REFERENCE RANGE	FLAG
Total Cholesterol	6.4	mmol/L	< 5.0	HIGH
LDL Cholesterol	4.1	mmol/L	< 3.0	HIGH
HDL Cholesterol	1.2	mmol/L	> 1.0	Normal
Triglycerides	1.8	mmol/L	< 1.7	HIGH
Fasting Glucose	4.9	mmol/L	3.9 - 5.5	Normal



F-07 — Sensitive Metadata Embedded in Patient PDF Files

Severity: Medium

Finding: The evidence identifies sensitive metadata embedded in patient_report_3.pdf. Document metadata can disclose information such as author or creator details, software, timestamps, internal paths, or other generation details, depending on the document-production process.

Recommendation: Sanitize PDF metadata before external delivery and establish a controlled document-generation process that removes unnecessary author, application, path, and other internal metadata.

Figure 1 below remains the primary visual evidence for F-01. The additional findings above are documented from the content of the supplied assessment images and are intentionally not reproduced as separate figures.

3.1 Visual Evidence

The following figures summarize the sensitive data identified in the exposed SQL backup. Individual national IDs, email addresses and phone numbers are omitted from the report visuals to minimize unnecessary reproduction of sensitive personal identifiers.

Staff Table — Exposed Records

Sensitive identifiers (national IDs, emails and phone numbers) intentionally omitted.

ID	Name	Job Title	Department	Monthly Salary (ZAR)	Date Joined
1	Dr. Rajesh Naidoo	Chief Pathologist	Diagnostics Lab	138,000	2009-03-16
2	Sarah Botha	Chief Financial Officer	Finance	152,000	2011-07-01
3	Dr. Johan van der Merwe	Medical Director	Management	160,000	2007-01-22
4	Dr. Anita Naicker	Consultant Cardiologist	Cardiology	132,000	2012-09-10
5	Dr. Ahmed Kara	Consultant Physician	Internal Medicine	128,000	2013-02-18
6	Dr. Yusuf Cassim	Senior Registrar	Emergency & Trauma	74,000	2018-05-04
7	Michael Roberts	HR Director	Human Resources	96,000	2010-11-15
8	Susan Pretorius	HR Officer	Human Resources	32,000	2016-08-23
9	Jameel Malik	IT Systems Administrator	IT	58,000	2015-04-12
10	Thabo Molefe	Network Engineer	IT	46,000	2017-10-02
11	Nomvula Khumalo	Registered Nurse	Emergency & Trauma	34,000	2016-01-19
12	Lerato Mokoena	Registered Nurse	Pediatrics	33,000	2017-06-07
13	Bongani Ndlovu	Registered Nurse	Cardiology	35,000	2015-12-01
14	Zanele Mahlangu	Nursing Sister	Theatre	42,000	2013-03-25
15	Kagiso Sithole	Pharmacist	Pharmacy	61,000	2014-09-08
16	Naledi Zulu	Pharmacy Assistant	Pharmacy	26,000	2019-02-14
17	Themba Nkosi	Radiographer	Radiology	44,000	2016-07-30
18	Palesa Radebe	Radiographer	Radiology	43,000	2017-04-11
19	Deepak Pillay	Lab Technologist	Diagnostics Lab	41,000	2015-05-20
20	Kavitha Govender	Lab Technician	Diagnostics Lab	35,000	2018-08-06
21	Dr. Suresh Moodley	Consultant Radiologist	Radiology	130,000	2012-02-28
22	Dr. Fatima Patel	Pediatrician	Pediatrics	118,000	2013-10-17
23	Nisha Singh	Physiotherapist	Rehabilitation	48,000	2016-11-09
24	Dr. Vikram Chetty	Anaesthetist	Theatre	135,000	2011-06-13
25	David Smith	Facilities Manager	Operations	52,000	2014-01-27
26	Karen O'Connor	Billing Administrator	Finance	29,000	2018-03-19

Figure 2 — Staff table showing exposed employee and salary records.

Shareholders Table — Exposed Records

Ownership and shareholding information contained in the exposed database backup.

ID	Shareholder	Ownership	Shares Held	Share Class
1	Dr. Rajesh Naidoo	18%	180,000	Ordinary
2	Cedar Health Holdings (Pty) Ltd	15%	150,000	Ordinary
3	Dr. Johan van der Merwe	12%	120,000	Ordinary
4	Reddy Family Trust	11%	110,000	Ordinary
5	Thabo Molefe	10%	100,000	Ordinary
6	Sarah Botha	9%	90,000	Ordinary
7	Dr. Ahmed Kara	8%	80,000	Preferential
8	Naledi Zulu	7%	70,000	Ordinary
9	Michael Roberts	6%	60,000	Ordinary
10	Dr. Vikram Chetty	4%	40,000	Preferential

Figure 3 — Shareholders table showing exposed ownership records.

Database Exposure — Evidence Summary

Report-ready summary of the sensitive data identified in the SQL backup.

Component	Records	Information Exposed	Security Impact
staff	30	Names, job titles, departments, emails, phones, national IDs, sal..	Highly sensitive personal & financial data
shareholders	10	Names, ownership %, shares held, share classes	Confidential corporate ownership data
Database	—	mediroza_hr	Reveals internal database name
Backup	—	mediroza_db_backup_2019.sql	Indicates exposed database backup
CMS	—	Mediroza CMS 1.4.2	Reveals application/version information

Figure 4 — Summary of the database components and sensitive information exposed.

4. Risk Rating

Finding	Severity	Primary Risk
F-01 — Unauthenticated Directory Listing	Medium	Application structure and sensitive functionality disclosed
F-02 — Confidential Internal SQL Database Backup Exposure	Critical	Staff personal/salary and shareholder ownership information exposed
F-03 — Username Enumeration	Medium	Account discovery can support targeted authentication attacks
F-04 — SQL Injection Login Bypass	Critical	Authentication control can be bypassed
F-05 — Confidential PDFs Accessible After Login Bypass	High	Potential unauthorized access to sensitive patient reports
F-06 — Weak PDF Passwords	High	Document protection can be defeated with a wordlist
F-07 — Sensitive PDF Metadata	Medium	Document metadata may disclose additional sensitive information

Ratings are based on demonstrated impact and exploitability within the authorized assessment.

The directory listing is classified as Medium because it demonstrates information disclosure and attack-surface expansion but does not by itself demonstrate compromise of patient records. The SQL backup exposure is Critical because of the breadth and sensitivity of the information contained in the artifact.

5. Recommendations and Remediation

5.1 Immediate Remediation

- Remove the exposed database backup from all publicly accessible locations immediately.
- Determine how the backup became accessible and review access logs.
- Disable directory indexing for /patient/ and other sensitive directories.
- Review and protect error_log, download.php, portal.php and reports/.

5.2 Authentication and Authorization

- Enforce authorization at the server-side resource level.
- Require each sensitive resource to independently verify that the requesting user is authorized.
- Review direct access controls for report download and portal functionality.

5.3 Secure Backup Management

- Store backups outside web roots.
- Encrypt backups at rest.
- Use strong access controls and separate backup credentials.
- Apply retention and secure-deletion policies.
- Regularly scan web-accessible locations for exposed backup files.

5.4 Sensitive Data Protection

- Minimize exposure of national identification, contact, salary and shareholder information.
- Restrict sensitive information to personnel and systems with a legitimate business requirement.

5.5 Logging and Monitoring

- Review access logs for /patient/, /patient/reports/, /patient/download.php, /patient/error_log and backup-file extensions.
- Implement monitoring and alerting for attempts to access sensitive files.

6. Reconnaissance Observations

6.1 Network Services

Nmap identified externally accessible services including:

21 FTP | 25 SMTP proxy | 26 SMTP/Exim | 53 DNS/BIND | 80 HTTP proxy | 110 POP3 | 143 IMAP | 443 HTTPS | 465 SMTPS | 587 SMTP | 993 IMAPS | 995 POP3S

The host was identified as server274-1.web-hosting.com and appeared to operate behind a hosting/load-balancing environment. The presence of these services alone does not establish a vulnerability.

6.2 robots.txt

```
/patient/
/staff/
/old/
```


These paths provide reconnaissance information but are not independently classified as vulnerabilities.

6.3 Sitemap

- /index.html
- /about.html
- /doctors.html
- /contact.html

6.4 Staff Login Endpoint

- /staff/login.php

The existence of this endpoint does not demonstrate an authentication vulnerability without evidence of bypass or credential compromise.

7. Testing Limitations

The web application employed anti-automation/browser verification behavior on some requests. Automated requests to /patient/ initially returned a browser-verification response rather than the underlying application, requiring browser-based inspection to identify the actual directory listing.

Direct access to /patient/reports/ returned HTTP 403 Forbidden. Therefore, the existence of the reports directory was confirmed, but direct directory browsing of /reports/ was not demonstrated.

The presence of error_log was identified through directory enumeration, but the report does not claim that its contents were publicly readable because that was not separately demonstrated. Similarly, the report does not claim an authentication bypass, IDOR, or direct unauthorized access to patient PDF reports where those outcomes were not conclusively demonstrated.

8. Overall Conclusion

The black-box assessment identified significant information-disclosure weaknesses within the Mediroza General Hospital environment. The most significant confirmed issue was the exposure of an internal SQL database backup containing confidential employee and shareholder information. The backup contained populated staff records including salary and national identification information, as well as shareholder ownership information.

A separate medium-severity issue was identified through unauthenticated directory listing of the /patient/ directory. This exposed application components and directories that should not have been enumerated by an unauthenticated user.

The assessment also identified several reconnaissance points, including /staff/ and /patient/ application areas, a staff login endpoint, public robots.txt entries, and externally exposed network services. These should be reviewed as part of broader hardening, although they are not individually considered confirmed vulnerabilities without additional evidence.

The highest priority remediation is to remove and secure the exposed database backup, investigate potential access to the exposed data, disable directory indexing, and review access controls around all patient-related resources.

9. Evidence Summary

Evidence	Result	Status
nmap -sV medirozahospital.com	Multiple externally accessible services identified	Confirmed
/robots.txt	/patient/, /staff/, /old/ disclosed	Confirmed
/patient/	Directory listing exposed application files	Confirmed — F-01
/patient/reports/	403 Forbidden	Access controlled
/staff/login.php	Login endpoint identified	Reconnaissance
mediroza_db_backup_2019.sql	Internal database backup containing staff/shareholder records	Confirmed — F-02
staff table	30 employee records including salary and sensitive identifiers	Confirmed impact
shareholders table	10 shareholder records and ownership information	Confirmed impact

```
kali@kali: ~/Mediroza
$ nmap -sV medirozahospital.com
Starting Nmap 7.99 ( https://nmap.org ) at 2026-10-01 16:32 -0400
Nmap scan report for medirozahospital.com (199.188.201.16)
Host is up (0.036s latency).
rDNS record for 199.188.201.16: server274-1.web-hosting.com
Not shown: 987 filtered tcp ports (no-response)
PORT      STATE SERVICE      VERSION
20/tcp    closed ftp-data
21/tcp    open  ftp          Pure-FTPd
25/tcp    open  smtp-proxy   ISP SMTP block
26/tcp    open  smtp        Exim smtpd 4.100.1
53/tcp    open  domain      (unknown banner: BIND)
80/tcp    open  http-proxy   HAProxy http proxy 2.0.0 or later
110/tcp   open  pop3         Dovecot pop3d
143/tcp   open  imap        Dovecot imapd
443/tcp   open  ssl/http-proxy HAProxy http proxy 2.0.0 or later
445/tcp   open  ssl/smtp    Exim smtpd 4.100.1
587/tcp   open  smtp        Exim smtpd 4.100.1
993/tcp   open  ssl/imap    Dovecot imapd
995/tcp   open  ssl/pop3    Dovecot pop3d

1 service unrecognized despite returning data. If you know the service/version, please submit the following fingerprint at https://nmap.org/cgi-bin/submit.cgi?new-service :
_
SF:Port53-TCPIP:V=7.99I=7%D=10/1kTime=6ABEC384%P=x86_64-pc-linux-gnuSr(DNSV
SF:ersionBindReqTCP,3F,"0"=0\0x06\0x85\0\0x01\0\0x01\0\0x01\0\0\0x04\0\0x08\0\0x01\0\0x03\0\0x03\0\0x0c\0\0x0c\0\0x01\0\0x03\0\0\0\0\0\0x05\0x04B1NDxc0\0xc0\
SF:0\0x02\0\0x03\0\0\0\0\0\0x02\0\0x0c\0\0x0c");
Service Info: Host: server274.web-hosting.com; Device: load balancer

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 62.18 seconds
```

```

kali@kali: ~/Mediroza
$ curl -I https://medirozahospital.com
$ curl https://medirozahospital.com/robots.txt
$ curl https://medirozahospital.com/sitemap.xml
HTTP/2 200
content-type: text/html
last-modified: Fri, 04 Sep 2026 02:03:12 GMT
accept-ranges: bytes
content-length: 5445
date: Thu, 01 Oct 2026 20:30:01 GMT
server: LiteSpeed
x-turbo-charged-by: LiteSpeed

# robots.txt
User-agent: *
Disallow: /patient/
Disallow: /staff/
Disallow: /old/

Sitemap: https://medirozahospital.com/sitemap.xml
<?xml version="1.0" encoding="UTF-8"?>
<urlset xmlns="http://www.sitemaps.org/schemas/sitemap/0.9">
  <url><loc>https://medirozahospital.com/index.html</loc></url>
  <url><loc>https://medirozahospital.com/about.html</loc></url>
  <url><loc>https://medirozahospital.com/doctors.html</loc></url>
  <url><loc>https://medirozahospital.com/contact.html</loc></url>
</urlset>

```

```

kali@kali: ~/Mediroza
$ wafw00f medirozahospital.com
[*] Checking https://medirozahospital.com
[*] The site https://medirozahospital.com is behind LiteSpeed (LiteSpeed Technologies) WAF.
[-] Number of requests: 2

```

The combined findings show that the patient-portal attack surface includes weaknesses in directory exposure, authentication, report authorization, document protection, and document metadata, while the separate database-backup exposure represents a broader internal-data confidentiality issue. Findings F-03 through F-07 are incorporated from the supplied assessment evidence and should be validated against the application during remediation or retesting.